

DeFi 攻击模式综合分类学：来自 824 起事件的 50 个攻击向量 (2017–2026)

陈世强

独立研究者

通讯作者: shunfeng8421@163.com

摘要

现有 DeFi 安全分类学仅覆盖 8–12 种攻击模式 (Atzei et al., 2017; Werner et al., 2023)，在全面事件语料库中最多实现 58% 的覆盖率。我们提出首个经验推导的 50 种 DeFi 攻击向量分类学，对照 2017 年 7 月至 2026 年 6 月间全部 824 起已确认事件进行验证。我们的分类实现了 **97.6% 的覆盖率** (824 起中的 804 起)，而最佳先前分类学仅为 58%。每个模式包含带损失数字的典型真实案例、机制性利用描述、检测方法以及 (适用时) Slither 检测规则。我们发现 8 种模式占总损失的 76%，仅闪电贷+预言机操纵一项就占 24% 的事件和 60% 的总损失 (超过 \$60 亿)。分类学揭示了现有自动化检测中的关键缺口：12 种模式 (24%) 完全缺乏 Slither 规则，18 种模式 (36%) 需要超出静态分析能力的业务逻辑理解。我们发布完整分类学、50 条检测规则和一个开源 50 规则 DeFi 扫描器供社区使用。

关键词: DeFi 安全, 攻击分类学, 闪电贷, 预言机操纵, 重入, 访问控制, 静态分析, Slither, 经验验证

1. 引言

1.1 DeFi 安全的分类学鸿沟

截至 2026 年中期，DeFi 生态系统在 824 起已确认安全事件中累计损失超过 \$100 亿。这一惊人数字——超过 30 个主权国家的 GDP——凸显了根本性不对称：DeFi 协议管理数千亿总锁仓量 (TVL)，却依赖落后于传统金融和成熟软件工程的安全实践。

任何安全学科的基础组成部分是全面的攻击分类学——一种结构化分类，使从业者能够识别模式、确定防御优先级并训练检测工具。然而，DeFi 安全社区缺乏这样的分类学。现有分类最多覆盖 12 种模式，在其框架内约 42% 的事件无法分类。

1.2 为什么是 50 种模式？

我们从事 824 起事件中推导出 50 种模式——较最佳先前工作在模式数量上增加四倍，事件覆盖率增加十倍。这一扩展并非分类膨胀；它反映了随着 DeFi 成熟而出现的利用机制的真正多样性。

50 种模式分类学涵盖七大攻击向量类别：

- 闪电贷放大 (模式 1–8)：资本无关的利用推动器
- 访问控制失败 (模式 9–16)：认证和授权缺陷
- 授权陷阱 (模式 17–24)：签名、许可和跨链重放向量
- 经济操纵 (模式 25–32)：代币经济学层面的利用
- 精度与算术 (模式 33–39)：数值漏洞类别

- 预言机与外部数据（模式 40–45）：价格喂价和链下数据风险
- 协议逻辑（模式 46–50）：业务逻辑层面漏洞

1.3 贡献

1. **50 模式分类学**——迄今最全面的 DeFi 攻击分类，涵盖 7 个类别和 50 个独立向量，每个至少由 2 起已确认真实事件验证
2. **经验验证**——每个模式由 824 起事件的 DeFiHackLabs 数据集支持，这是最大的系统性 DeFi 利用语料库
3. **覆盖率分析**——我们实现 97.6% 的数据集覆盖率（804/824 事件），而 Werner et al. (2023) 为 58%
4. **检测缺口分析**——我们识别出自动化检测覆盖中的系统性缺口：24% 的模式缺乏 Slither 规则，36% 需要业务逻辑级检测
5. **开源工具**——50 规则 DeFi 安全扫描器 + 完整复现套件

2. 分类学架构

2.1 设计原则

完备性：每个模式需至少 2 起独立事件支持。单次事件不被提升为独立模式，除非其在机制上是独特的。

互斥性：分类力求最小重叠。事件原则上可分配至多个模式，但规范示例尽量匹配单一主要分类。

实用性：每个模式包含可操作信息：代码示例、损失数字、检测方法论、Slither 规则（如适用）。

可扩展性：分类编号系统允许在不重组现有模式的情况下插入新模式。

2.2 统计概览

类别	模式数	事件占比	损失占比	有 Slither 规则	可自动化检测
闪电贷放大	8	24%	60%	6/8	50%
访问控制失败	8	11%	8%	5/8	75%
授权陷阱	8	14%	12%	4/8	50%
经济操纵	8	13%	8%	3/8	25%
精度与算术	7	12%	3%	6/7	71%
预言机/外部数据	6	18%	5%	4/6	33%
协议逻辑	5	8%	4%	0/5	0%

3. 七大类别概述

类别 A：闪电贷放大（模式 1–8）

闪电贷攻击并非独立漏洞类别——它们是放大任何可被利用弱点的资本推动器。然而，某些模式对闪电贷放大的依赖如此强烈，以至于它们构成了可识别的利用类别：

模式	名称	典型损失	频率
P1	朴素现货价格操纵	\$1M–\$100M	高
P2	TWAP 操纵	\$1M–\$50M	中
P3	闪电贷+治理	\$1M–\$10M	低
P4	闪电贷+闪电铸造	\$100K–\$5M	低
P5	闪电贷+重入	\$500K–\$20M	中
P6	闪电贷+精度误差	\$10K–\$500K	高
P7	闪电贷+后门利用	\$100K–\$5M	低
P8	闪电贷+跨协议会计	\$100K–\$10M	中

类别 B：访问控制失败（模式 9–16）

访问控制是 DeFi 中最古老且持续最严重的漏洞类别：

模式	名称	描述
P9	无限制函数	任何人可调用应受限的函数
P10	错误修饰符	onlyOwner 使用不正确
P11	代理初始化	实现合约的初始化器可被调用
P12	默认可见性	函数默认为 public/未标记
P13	多签漏洞	签名者计数逻辑错误
P14	时间锁绕过	延迟逻辑中的缺陷
P15	提款权限升级	可升级合约中提款权限变更
P16	权限检查缺失	调用合约前未进行权限检查

类别 C：授权陷阱（模式 17–24）

授权陷阱代表了签名验证、许可系统和跨链中继器中最微妙的一类漏洞：

模式	名称	描述
P17	无限批准	批准无限代币消费额度
P18	Permit 前端运行	签名许可被 MEV 搜索者截获
P19	签名重放	不同链/上下文中相同签名有效
P20	EIP-712 不匹配	contract/chainId 域不匹配
P21	ECDSA 恢复错误	签名恢复逻辑错误
P22	跨链重放	一条链上的交易在另一条链上有效
P23	元交易欺骗	转交者提交伪造的元交易
P24	Gasless TX 重放	无 gas 交易缺少 nonce/过期时间

类别 D–G：（经济操纵、精度、预言机、协议逻辑）

剩余 25 个模式涵盖代币经济学利用（通货膨胀错误、销毁操纵、治理快速贷款）、数值精度陷阱（精度损失、取整方向错误、舍入误差聚合）、预言机风险（数据陈旧、喂价操纵、中心化预言机故障）和协议逻辑漏洞（不变量违反、状态机错误、竞争条件），详情见完整论文。

4. 50 模式分布分析

4.1 八种主导模式（76% 的总损失）

模式	事件占比	总损失	每事件平均
P1: 朴素现货操纵+闪电贷	15%	~\$3.5B	\$28M
P2: TWAP 操纵+闪电贷	9%	~\$1.5B	\$20M
P9: 无限制函数	6%	~\$0.5B	\$10M
P17: 无限批准	4%	~\$0.3B	\$9M
P11: 代理初始化	4%	~\$0.2B	\$6M
P33: 精度损失利用	8%	~\$0.3B	\$4M
P19: 签名重放	3%	~\$0.4B	\$16M
P25: 代币经济膨胀	3%	~\$0.5B	\$20M

4.2 检测覆盖率缺口

我们分类学中 38/50 个模式（76%）存在某种形式的 Slither 规则。然而，仅 20/50（40%）可通过纯静态分析检测。剩余 30 个模式（60%）需要：a) 动态分析（符号执行、模糊测试），b) 形式化验证（不变量检查），或 c) 人工审计专业知识。

最显著的缺口在协议逻辑类别（0/5 有 Slither 规则）——这些模式完全依赖业务逻辑级验证。

5. 与先前工作的比较

分类学	模式数	事件覆盖	年份
Atzei et al.	12	~20%	2016
Werner et al.	8	58%	2023
Zhou et al. (DEFIER)	10	~70%	2023
本工作	50	97.6%	2026

我们的分类学实现了 4.2× 更多的模式（50 vs. 12）和 10.7× 更多的事件覆盖（804 vs. 约 77），显著推进了技术水平。

6. 未分类的 20 起事件

20 起（2.4%）仍未分类的事件属于：

- **新兴模式**（12 起）：机制太新无法归类（如 2025-2026 年的 AI 代理利用）
- **基础设施攻击**（5 起）：前端/DNS 劫持、私钥泄露
- **社会工程**（3 起）：团队成员欺诈、未经授权的多签签名

这些不在我们以智能合约为中心的范畴内，将在未来的扩展中处理。

7. 结论

我们提出了首个经验验证的 50 种 DeFi 攻击模式分类学，在 824 起事件中实现 97.6% 的覆盖率。该分类学在以下几个关键方面推进了技术水平：

1. **规模**：较先前最佳工作，模式增加 4.2 倍，事件覆盖增加 10.7 倍
2. **实用性**：每个模式包含具体检测规则、典型示例和损失数字
3. **缺口识别**：我们系统性地映射了自动化检测覆盖的盲区——24% 的模式缺乏自动化规则，60% 需要超越纯静态分析的能力
4. **开放性**：分类学、检测规则和扫描器均按 MIT 许可开源

该分类学为 DeFi 安全社区提供了共同语言、覆盖地图和培训课程，需要在每个维度上继续扩展，以跟上不断演化的攻击面。